

NEOLABS

SECURITY LABS | GREY-BOX PENTEST

Week 1 Launch Pack — Operation Night Watch

Weekly Learning Pack | Learn + Connect + Operate

Programme: NeoLabs x Renaissance Innovation Labs Cybersecurity Internship

Week 01

Version: 1.0

Classification: Student Training Material

Authorised synthetic training use only.

Your objective

Create a safe, reproducible map of the **authorised VCC application and its normal HTTP/service behaviour**. Week 1 is a baseline/mapping exercise, not a vulnerability hunt.

Windows — start in this order

- 1 Pull the latest Grey-Box toolkit.
- 2 Run `setup-windows.cmd` once.
- 3 Open PowerShell in the toolkit folder and authenticate:

```
.\neolabs.cmd login
.\neolabs.cmd status
.\neolabs.cmd pod info
.\neolabs.cmd scope
.\neolabs.cmd targets
.\neolabs.cmd connect
```

Windows interns do **not** need a global `pip install`, `PATH` edit or manually entered gateway URL for the current programme flow.

`login` uses only your assigned pod + private Access Code. The server controls your track/pod/current resources.

During the approved Week 1 live window, keep `connect` running and use the pod-isolated learner surface, normally:

```
http://127.0.0.1:18080
```

Confirm `scope` and `targets` immediately before testing. Do not substitute the public EC2 address, an old IP/hostname, guessed CIDR or another pod. If no current live target is published, stop live-target work.

Read before touching the target

- `RULES_OF_ENGAGEMENT.md`
- `PROGRAMME_CURRENT_STATE.md`
- `docs/01-professional-foundations/`
- `docs/02-http-browser-foundations/`
- `docs/03-burp-suite/`
- `docs/04-application-mapping/`
- current Burp/tool setup guidance
- application-mapping worksheet/template

Safe Week 1 workflow

- 1 Confirm the exact current server-issued scope/local tunnel target.
- 2 Configure Burp Suite so only the authorised target is in scope.
- 3 Use the repository's approved low-impact Nmap/discovery wrapper only if the current assignment/manifest exposes network scope.
- 4 Browse the normal learner workflow through Burp Proxy.

- 5 Record methods, paths, status codes, cookies/session indicators, JSON/API responses and important object identifiers.
- 6 Replay two **normal, non-state-changing** requests in Repeater and explain each.
- 7 Note observable controls without bypassing them: authentication requirements, redirects, validation, authorisation boundaries and security headers.
- 8 Produce a service/request/application map for later comparison.

Week 1 tasks

- Record student-facing services exposed by the approved target.
- Complete the Application Mapping Workbook/worksheet.
- Capture at least five normal requests from different learner functions.
- Document two safe Repeater observations.
- Record visible security controls without bypass attempts.
- Build a concise attack-surface/service map.

Deliverables

- `service-and-request-map.md`
- completed Application Mapping Workbook
- `testing-journal.md`
- `evidence-register.md`
- redacted screenshots/HTTP evidence where useful

Official graded submissions go to `RIL_NeoLabs-Intern-Assignments`.

Evidence standard

Every observation should include current authorised target/scope, time, method/tool, result and enough evidence for another tester to reproduce it. Redact Access Codes, credentials, session tokens, signed URLs and personal data.

Prohibited in Week 1

- broad scanning;
- brute force/credential spraying;
- automated exploitation;
- destructive/state-changing tests;
- scanning targets not in the current manifest/assignment;
- public-EC2 substitution;
- cross-pod attempts;
- denial-of-service/high-rate traffic.

Stop conditions

Stop immediately and contact a mentor if a request reaches an unassigned host/pod, real data/credentials appear, unexpected state changes occur, the proof threshold is reached, availability is affected or infrastructure outside the student boundary is exposed.

Before submission

- ☐ Current **status** shows the correct pod and PENTEST track.
- ☐ Current **scope/targets** match what I actually tested.
- ☐ Week 1 local tunnel was used rather than an old/public target.
- ☐ Burp contains only the authorised target in scope.
- ☐ Any Nmap use stayed inside the approved low-impact profile/current network scope.
- ☐ Five normal requests are documented.
- ☐ No destructive/exploit testing was performed.
- ☐ Evidence is reproducible and redacted.